

Vulnerability Assessment Report for a live website

Security Assessment Summary

A passive security scan using OWASP ZAP identified multiple security misconfigurations related to HTTP security headers and cache handling. These issues may expose users and the organization to unnecessary security risks if left unresolved.

Assessment Scope

The penetration testing activity was conducted on the official OWASP Juice Shop demo website for educational and security testing purposes.

Testing Details

Item	Details
Testing Type	Passive Web Application Penetration Testing
Tool Used	OWASP ZAP
Target Website	OWASP Juice Shop Demo Website
Assessment Method	Passive Scan
Objective	Identify common web application security misconfigurations and vulnerabilities
Findings Identified	Missing HSTS Header, Cache-related Security Issue

Scope Statement

This assessment was conducted in a controlled educational environment on an intentionally vulnerable demo application designed for cybersecurity learning and penetration testing practice. No unauthorized systems were targeted during this activity.

Identified Vulnerabilities

Vulnerability	Risk Level	Description
Missing HTTP Strict Transport Security (HSTS) Header	Medium	The application does not enforce secure HTTPS-only communication.
Retrieved from Cache	Low	Sensitive information may be stored in shared browser or proxy caches.

Detailed Findings

1. Missing HTTP Strict Transport Security (HSTS) Header

Risk Level: Medium

What is the Issue?

The web server is not sending the HTTP Strict Transport Security (HSTS) header. HSTS tells browsers to communicate with the website only through secure HTTPS connections.

Why Does it Matter?

- Data transmitted between users and the website may be intercepted.
- Attackers on public Wi-Fi networks could perform man-in-the-middle attacks.
- Sensitive information such as login credentials or session cookies could be exposed.

Business Impact

- Reduced customer trust
- Increased exposure to network-based attacks
- Potential compliance and security policy violations

Practical Remediation Steps

Recommended Fixes

Configure the web server to enforce HTTPS using the HSTS header.

Example configuration:

Strict-Transport-Security: max-age=31536000; includeSubDomains

Additional Recommendations

- Redirect all HTTP traffic to HTTPS.
- Ensure valid SSL/TLS certificates are installed.
- Regularly test HTTPS configuration.

OWASP ZAP Passive Scan Security Findings



The screenshot shows the OWASP ZAP interface with the 'Alerts' tab selected. An alert titled 'Strict-Transport-Security Header Not Set (3)' is highlighted. The alert details include:

- Alert Reference:** 10035-1
- Input Vector:**
- Description:** HTTP Strict Transport Security (HSTS) is a web security policy mechanism whereby a web server declares that complying user agents (such as a web browser) are to interact with it using only secure HTTPS connections (i.e. HTTP layered over TLS/SSL). HSTS is an IETF standards track protocol and is specified in RFC 6797.
- Other Info:**
- Solution:** Ensure that your web server, application server, load balancer, etc. is configured to enforce Strict-Transport-Security.
- Reference:**
 - https://cheatsheetsseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
 - <https://owasp.org/www-community/Security-Headers>
 - https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
- Alert Tags:**

Key	Value
OWASP_2017_A06	https://owasp.org/www-project-top-ten/2017/A6_2017-Security_Misconfiguration.html
POLICY_QA_STD	
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

2. Retrieved from Cache

Risk Level: Low

What is the Issue?

Some application responses may be stored in browser or shared proxy caches. If sensitive pages are cached, another user on the same system or network may potentially access previously viewed information.

Why Does it Matter?

Cached sensitive information can expose:

- Usersession details
- Personal information
- Confidential business data

This risk becomes more serious in:

- Sharedcomputers
- Corporate proxyenvironments
- Public systems

Business Impact

- Minor information exposure risk
- Privacy concerns
- Possible unauthorized access to cached content

Practical Remediation Steps

Recommended Fixes

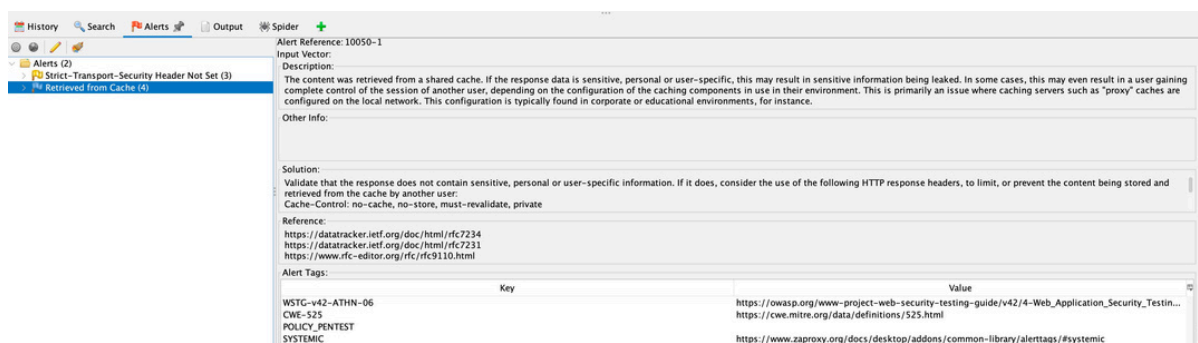
Prevent sensitive pages from being cached by adding proper HTTP response headers:

Cache-Control: no-cache, no-store, must-revalidate, private

Additional Recommendations

- Avoid caching authenticated user pages.
- Review server and proxy cache policies.
- Test sensitive workflows after applying headers.

OWASP ZAP Passive Scan Security Findings



The screenshot shows the OWASP ZAP interface with the Alerts tab selected. An alert titled 'Strict-Transport-Security Header Not Set (3)' is highlighted. The alert details include:

- Alert Reference:** 10050-1
- Input Vector:**
- Description:** The content was retrieved from a shared cache. If the response data is sensitive, personal or user-specific, this may result in sensitive information being leaked. In some cases, this may even result in a user gaining complete control of the session of another user, depending on the configuration of the caching components in use in their environment. This is primarily an issue where caching servers such as "proxy" caches are configured on the local network. This configuration is typically found in corporate or educational environments, for instance.
- Other Info:**
- Solution:** Validate that the response does not contain sensitive, personal or user-specific information. If it does, consider the use of the following HTTP response headers, to limit, or prevent the content being stored and retrieved from the cache by another user:
Cache-Control: no-cache, no-store, must-revalidate, private
- Reference:**
 - <https://datatracker.ietf.org/doc/html/rfc7234>
 - <https://datatracker.ietf.org/doc/html/rfc7231>
 - <https://www.rfc-editor.org/rfc/rfc9110.html>
- Alert Tags:**

Key	Value
WSTG-v42-ATHN-06	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testin...
CWE-525	https://cwe.mitre.org/data/definitions/525.html
POLICY_PENTEST	
SYSTEMIC	https://www.zaproxy.org/docs/desktop/addons/common-library/alerttags/#systemic

Conclusion

The assessment identified security misconfigurations related to HTTPS enforcement and cache management. While no critical vulnerabilities were discovered during this passive scan, improving HTTP security headers and cache controls will strengthen overall application security and reduce exposure to common web-based attacks.

Immediate attention is recommended for implementing HSTS, while cache-control improvements should also be addressed as part of secure web application hardening practices.